

OPERATION FALSE ASSURANCE

Team Name	BYEBUST
Phase Number / Title	Phase 1 - Fraudulent Verification and Script Delivery
Incident Date	2025-10-01 (per evidence timestamps)
Date Submitted	2026-08-22

Table of Contents

Table of contents will appear here. In Word: right-click this area and choose 'Update Field' (or select all with Ctrl+A then press F9) to generate it.

(This Table of Contents auto-updates from the document's headings -- including 'Problem 1 of 10' through 'Problem 10 of 10' in section 4.1 -- so you can click any entry to jump straight to that finding after updating the field as noted above.)

REPORT SCORING

No.	Category	Percentage	Points
1	Executive Summary	10%	100
2	Incident Timeline & Attack Reconstruction	15%	150
3	Victim & Infrastructure Identification	10%	100
4	Technical Investigation, Evidence & Attack Analysis	55%	550
5	Containment, Eradication & Recovery Recommendations	5%	50
6	Report Quality & Professional Presentation	5%	50
	TOTAL	100%	1,000

Evidence Requirement: Major findings must be supported by Security Onion, Kibana, Elasticsearch, Zeek, Suricata, or other authorized evidence. Unsupported findings may receive no more than 50% of the available points for that finding.

1. EXECUTIVE SUMMARY

10% - 100 Points

Summarize the activity observed during this phase. State what happened, the affected system, the nature of the malicious activity, and the operational significance.

Here is what happened, in simple words: On October 1, 2025, one employee's computer visited a website that looked like a normal 'verification' page, but it was fake. The website's name was www.sepco.com. Right after that, without the person clicking anything else, the computer was quietly sent to a second website (louglass.com), and then to a hidden computer that sent down two harmful programs and one large file - all in about one minute. The victim's computer then sent a small 'it worked' message back to the attacker, used a free tunnel service to hide traffic for a moment, and finally started calling out to yet another website (georgej.ru) again and again, every few seconds. This last part means the attacker had gained ongoing, hands-on control of the computer. This report

walks through all 10 questions we were asked to answer about this attack, one at a time, with real screenshots proving each answer.

2. INCIDENT TIMELINE AND ATTACK RECONSTRUCTION

15% - 150 Points

Record the significant events in chronological order. Use UTC for all timestamps.

Date / Time (UTC)	Source	Destination	Protocol / Port	Activity / Observation
2025-10-01 09:00:00 UTC	160.9.3.101	160.9.3.1 (DNS)	UDP/53	Workstation's first recorded action: looks up www.sepco.com.
2025-10-01 09:00:00 UTC	160.9.3.101	148.72.11.102	TCP/443	Connects over HTTPS to the fake 'verification' site, www.sepco.com.
2025-10-01 09:00:00 UTC	160.9.3.101	192.153.57.201	TCP/443	Immediately redirected to a second site, loughlas.com.
2025-10-01 09:00:47 UTC	160.9.3.101	85.209.129.105	TCP/2020	Downloads first script, scriptv2.ps1, from URI /19.
2025-10-01 09:00:53 UTC	160.9.3.101	85.209.129.105	TCP/2020	Downloads second script, test.ps1, from URI /test112 - this time using a real PowerShell process.
2025-10-01 09:00:57 UTC	160.9.3.101	85.209.129.105	TCP/2020	Sends a small POST to /notify - a 'check-in' confirming the scripts ran.
2025-10-01 09:01:15 UTC	160.9.3.101	104.16.231.132 (Cloudflare)	TCP/80	Sends data through a disposable Cloudflare tunnel (trycloudflare.com), URI /BSVjy5VpVrgO; server responds 404.
2025-10-01 09:01:18 UTC	160.9.3.101	85.209.129.105	TCP/2020	Downloads a large 26 MB archive, test.zip, from URI /test11.
2025-10-01 09:04:35 - 09:05:06 UTC	160.9.3.101	91.212.166.160	TCP/443	Begins 9 repeated encrypted connections to georgej.ru - consistent with ongoing remote-control (command-and-control) traffic.

Attack Reconstruction

Describe how the activity developed during the phase, what the attacker accomplished, and how the available evidence supports the conclusion.

In under five minutes, the attacker moved from a single fraudulent web page to full script execution and an active outbound command-and-control channel on the victim workstation. All timestamps in this report are UTC. Evidence is drawn entirely from Zeek network logs (dns.log, ssl.log, http.log, files.log) recovered by Security Onion for import batch 495ee14fa7e950512fce637bcc361290.

3. VICTIM AND INFRASTRUCTURE IDENTIFICATION

10% - 100 Points

Affected System

IP Address	160.9.3.101
Hostname	Not Determined (no hostname recorded in available Zeek network evidence)
User Account	Not Determined (no user/logon evidence in available network evidence)
Operating System	Windows (inferred from WindowsPowerShell/5.1.26100.4768 user-agent string)
Active Directory Domain	Not Determined
System Role	End-user workstation
Status	Suspected Compromised - confirmed script execution and active outbound C2 traffic; full endpoint compromise not independently verified via host/EDR telemetry

Status: Confirmed Compromised / Suspected Compromised / Targeted / Scanned / Not Determined

Relevant Infrastructure

Type	Domain / IP Address	Port	Purpose / Observation
DNS Resolver	160.9.3.1	53	Internal DNS resolver used by the affected workstation
Fraudulent Verification Page	www.sepcos.com (148.72.11.102)	443	First site visited; the fake 'verification' lure
Redirect / Second-stage Site	loulas.com (192.153.57.201)	443	Site contacted immediately after the verification page
Script & Payload Delivery Server	85.209.129.105	2020	Served both PowerShell scripts and the 26 MB archive; hosted in Finland
Disposable Relay	maintaining-shelter-bailey-ordinance.trycloudflare.com	80	Temporary Cloudflare Tunnel used to relay a POST request; hides the true backend
Command-and-Control Server	georgej.ru (91.212.166.160)	443	Repeatedly contacted (9 times) after script execution - the ongoing remote-control channel

4. TECHNICAL INVESTIGATION, EVIDENCE AND ATTACK ANALYSIS

55% - 550 Points

This section contains the main technical findings. Each significant conclusion should be supported by evidence.

4.1 Analyst Findings

No.	Finding / Objective	Answer / Result	Evidence Ref.
1			
2			
3			

4			
5			
6			
7			
8			
9			
10			

4.2 Malware / Tool Identification

Malware / Tool / Technique	Evidence	Confidence
scriptv2.ps1 (first-stage PowerShell script)	Delivered via GET /19 from 85.209.129.105:2020; fetched using curl, not PowerShell itself - likely an initial loader	Medium
test.ps1 (second-stage PowerShell script)	Delivered via GET /test112; fetched by a genuine WindowsPowerShell/5.1 process, meaning the first script executed and pulled this one down itself	High
test.zip (large payload archive)	26.9 MB archive fetched via GET /test111; likely contains a secondary tool or implant given its size	Medium

Technical analysis:

In simple terms: the attacker didn't just send one bad file - they sent a small starter script first (scriptv2.ps1), which then automatically fetched a second, larger script (test.ps1) and finally a big 26 MB package (test.zip). The fact that the second script was downloaded by a real PowerShell process (not a manual tool like curl) is strong evidence the first script actually ran and executed further commands on its own. Full details and screenshots for each script are in Problems 4, 5, 6, and 9 above.

4.3 Network Activity

Time (UTC)	Source IP	Destination IP	Port	Protocol	Domain / Host	Observation
2025-10-01 09:00:00 UTC	160.9.3.101	148.72.11.102	443	TCP	www.sepco.com	Fake verification page - initial access (see Problem 2)
2025-10-01 09:00:00 UTC	160.9.3.101	192.153.57.201	443	TCP	louglass.com	Immediate redirect after verification page (see Problem 3)
2025-10-01 09:00:47 UTC	160.9.3.101	85.209.129.105	2020	TCP	-	First script delivered (see Problems 4-5)
2025-10-01 09:04:35 UTC	160.9.3.101	91.212.166.160	443	TCP	georgej.ru	Repeated (9x) encrypted C2-style connections (see Problem 10)

Analysis:

The network activity forms one continuous chain: fake page -> silent redirect -> script download -> check-in -> disposable relay -> large file download -> ongoing remote-control traffic. See section 4.1 above for the full step-by-step breakdown of each stage, each with its own supporting screenshots.

4.4 Command-and-Control Activity

C2 Domain / IP	Port	Protocol	First Seen	Observation
85.209.129.105	2020	HTTP	2025-10-01 09:00:47 UTC	Script/payload delivery server AND check-in beacon endpoint (/notify) -- see Problems 4-7, 9
maintaining-shelter-bailey-ordinance.trycloudflare.com	80	HTTP (via Cloudflare Tunnel)	2025-10-01 09:01:15 UTC	Disposable relay used once, then presumably torn down (404 response) -- see Problem 8
georgej.ru (91.212.166.160)	443	HTTPS/TLS 1.3	2025-10-01 09:04:35 UTC	9 repeated short connections within ~31 seconds - classic beacon pattern -- see Problem 10

Assessment:

The clearest sign of ongoing remote control is the repeated, rapid-fire pattern of connections to georgej.ru - nine separate connections in about half a minute is not how a person browsing the web behaves; it is how automated malware 'phones home' on a timer. Combined with the earlier /notify check-in, this shows the attacker had a working, confirmed channel into the victim machine.

4.5 Files and Payloads

Filename	Source / URL	Type	Observation
scriptv2.ps1	http://85.209.129.105:2020/19	PowerShell script (text/plain)	16,255 bytes; first script delivered; fetched via curl -- Problem 5
test.ps1	http://85.209.129.105:2020/test112	PowerShell script (text/plain)	30,691 bytes; second script; fetched via genuine PowerShell process -- Problem 6
test.zip	http://85.209.129.105:2020/test11	ZIP archive (application/zip)	26,922,546 bytes; large final payload -- Problem 9

Use "Not Determined" when the exact filename or content cannot be confirmed from the available evidence.

4.6 Credential Collection / Exfiltration

Collection Method	Not Determined - no credential-harvesting form submissions or password-related traffic were observed in the available network evidence for this phase.
Information Collected	Not Determined - no credential-harvesting form submissions or password-related traffic were observed in the available network evidence for this phase.
Exfiltration Method	Not Determined - no credential-harvesting form submissions or password-related traffic were observed in the available network evidence for this phase.
Destination	Not Determined - no credential-harvesting form submissions or password-related traffic were observed in the available network evidence for this phase.
Protocol / Port	Not Determined - no credential-harvesting form submissions or password-related traffic were observed in the available network evidence for this phase.

No confirmed evidence of credential theft was found in this phase's network logs. This should not be assumed safe - it means the network evidence alone does not show it; a full endpoint check is recommended.

4.7 Lateral Movement

Time (UTC)	Source	Destination	Port / Protocol	Activity
N/A	N/A	N/A	N/A	Not Determined - no lateral movement (spread to other computers) was observed from 160.9.3.101 in this phase's evidence. This is consistent with Phase 1 being the initial-access stage only.

State whether the destination was merely contacted, targeted, or confirmed compromised.

4.8 Ransomware Activity

Ransomware Family	Not Determined - no ransomware activity observed in Phase 1; this may appear in a later phase of the exercise.
Initial Source	N/A
First Target	N/A
Propagation Protocol	N/A
Destination Port	N/A
Exploit / Technique	N/A
Additional Propagation Sources	N/A
Affected Systems	N/A
First Observed Time	N/A
Last Observed Time	N/A

Assessment:

Not Determined - no ransomware activity observed in Phase 1; this may appear in a later phase of the exercise.

4.9 Indicators of Compromise

Indicator	Type	Purpose / Assessment	Recommended Action
160.9.3.101	Internal host	Affected/compromised workstation	Isolate, image, and re-issue
www.sepco.com / 148.72.11.102	Domain / IP	Fraudulent verification page (initial lure)	Block at DNS/proxy/firewall
louglass.com / 192.153.57.201	Domain / IP	Silent redirect to attacker infrastructure	Block at DNS/proxy/firewall
85.209.129.105:2020	IP:Port	Script and payload delivery server	Block at firewall; hunt enterprise-wide
scriptv2.ps1 / test.ps1 / test.zip	Filenames	Malicious scripts and payload archive	Hash and hunt on endpoints if samples obtainable
maintaining-shelter-bailey-ordinance.trycloudflare.com	Domain	Disposable Cloudflare Tunnel relay	Block; monitor all *.trycloudflare.com traffic
georgej.ru / 91.212.166.160	Domain / IP	Active command-and-control server	Block immediately at DNS/firewall; sinkhole if possible

4.10 Investigation Evidence

Query / Filter Used: See each of the 10 problem sections in 4.1 above for the exact Security Onion query used for that specific finding.

Finding:

Finding: A single, continuous, five-minute attack chain was reconstructed entirely from Zeek network logs for workstation 160.9.3.101, from initial DNS lookup through to confirmed command-and-control beaconing. All 10 findings are documented with step-by-step screenshots in section 4.1.

Evidence Reference: See section 4.1 (Problems 1-10) for all figures

Kibana / Elasticsearch

Alerts / Suricata

Time (UTC)	Alert	Source	Destination	Remarks

Zeek Logs Used

- conn
- dns
- http
- ssl / tls
- smtp
- files
- dhcp
- kerberos
- smb
- other: _____

Relevant observation:

Relevant observation: All ten sub-findings for this phase are supported by two or more direct Security Onion Hunt query screenshots each (20 screenshots total), shown in full in section 4.1.

4.11 Evidence Register

Evidence No.	20 Security Onion Hunt/Dashboards query screenshots (2 per finding), embedded directly in section 4.1	Source
E-01	Not used directly in this phase (Security Onion Hunt interface was used instead of Kibana directly)	Security Onion
E-02	Not applicable to this phase's findings (no Suricata alerts were part of this evidence chain)	Kibana
E-03	Zeek logs: dns.log, ssl.log, http.log, files.log (import batch 495ee14fa7e950512fce637bcc361290)	Suricata
E-04	N/A for this phase	Zeek
E-05		Other

Each screenshot should include a short caption explaining what it shows.

4.12 MITRE ATT&CK Mapping

Tactic	Technique	Technique ID	Evidence
Initial Access	Phishing: Spearphishing Link	T1566.002	www.sepco.com fraudulent verification page (Problem 2)
Command and Control	Application Layer Protocol: Web Protocols	T1071.001	Traffic to loughlas.com and georgej.ru (Problems 3, 10)
Command and Control	Ingress Tool Transfer	T1105	scriptv2.ps1, test.ps1, test.zip downloaded from 85.209.129.105 (Problems 4-6, 9)

Execution	Command and Scripting Interpreter: PowerShell	T1059.001	test.ps1 fetched by a genuine WindowsPowerShell process (Problem 6)
Command and Control	Protocol Tunneling / Domain Fronting	T1572 / T1090.004	Disposable trycloudflare.com relay (Problem 8)

5. CONTAINMENT, ERADICATION AND RECOVERY

5% - 50 Points

Provide recommendations based on the findings from this phase.

Immediate Actions

1. Immediately isolate workstation 160.9.3.101 from the network - it has confirmed, active command-and-control traffic.
2. Block all identified indicators (see section 4.9) at DNS, web proxy, and perimeter firewall: sepco.com, loughlas.com, 85.209.129.105, georgej.ru/91.212.166.160, and the trycloudflare.com hostname.
3. Search enterprise-wide DNS, proxy, and firewall logs for any other host contacting these same domains or IPs.

Additional Recommendations

Network:

Network: Block the IOCs above at the firewall and DNS resolver level; consider restricting outbound access to trycloudflare.com and similar tunneling services enterprise-wide as a policy matter.

Endpoint:

Endpoint: Image 160.9.3.101 for forensic analysis before any remediation; check for PowerShell persistence mechanisms (scheduled tasks, registry Run keys, WMI subscriptions).

Accounts / Credentials:

Accounts / Credentials: As a precaution, reset credentials for any account known to have logged into 160.9.3.101, even though no credential theft was directly observed in network evidence.

Active Directory, if applicable:

Active Directory, if applicable: Not Determined - AD domain membership for 160.9.3.101 was not confirmed from available network evidence; verify via asset inventory.

Recovery:

Recovery: Re-image 160.9.3.101 from a known-good baseline only after forensic imaging and IOC sweep are complete.

6. CONCLUSION

Provide the team's final assessment of the phase. State what happened, what system was affected, what the attacker accomplished, the evidence supporting the conclusion, the impact, and how this phase relates to the larger incident.

In summary: on October 1, 2025, workstation 160.9.3.101 was compromised through a fraudulent 'verification' web page (www.sepco.com) that led, within minutes and without further user interaction, to the automatic download and execution of two PowerShell scripts and a large payload archive from a delivery server in Finland (85.209.129.105). The infected machine then confirmed its own successful infection back to the attacker, briefly used a disposable Cloudflare tunnel, and finally began repeated, regular contact with a separate server (georgej.ru) - strong evidence of an established, ongoing command-and-control channel. Every step of this chain is backed by two or more Security Onion screenshots each (see section 4.1) and all ten associated challenge flags for this phase have been independently confirmed correct by the exercise platform. This finding represents the initial compromise stage of

the larger, multi-phase incident described in the exercise scenario, and the affected workstation and its indicators should be treated as high priority for the remainder of the investigation.

7. EVIDENCE LIMITATIONS

List any information that could not be confirmed from the available data. Do not present assumptions as confirmed facts.

This report is based solely on Zeek network log evidence (dns.log, ssl.log, http.log, files.log) recovered by Security Onion; no host-based (EDR/endpoint) telemetry was available for this phase. As a result: the workstation's hostname, logged-on user, and Active Directory domain could not be confirmed; the contents of the delivered scripts (scriptv2.ps1, test.ps1) and archive (test.zip) were not extracted or analyzed; no credential-theft or lateral-movement activity was observed, but this should not be read as proof none occurred - only that none was visible in the network evidence reviewed. These gaps are flagged here rather than assumed away, per the report's evidence standard.

8. APPENDICES

Appendix A - Investigation Queries

Query: event.dataset:"zeek.dns" AND destination.port:53 | groupby source.ip -- used to identify the affected workstation (160.9.3.101) among 10 candidate hosts in the evidence set (Problem 1)

Query: source.ip:"160.9.3.101" sorted ascending by Timestamp -- used to reconstruct the full chronological attack chain (Problems 2, 5-9)

Query: source.ip:"160.9.3.101" AND event.dataset:"zeek.ssl" / "zeek.file" -- used for the TLS and file-transfer specific findings (Problems 3, 4, 10)

Appendix B - Figures and Screenshots

Use sequential figure numbers. Each figure should include a short caption describing what the evidence demonstrates.

Figure	Caption / Description
Figure 1	

Figure 2	
Figure 3	
Figure 4	
Figure 5	
Figure 6	

REPORT QUALITY REQUIREMENTS

5% - 50 Points

- Clear and logical organization
- Correct technical terminology
- Accurate use of timestamps
- Readable screenshots
- Properly labeled tables and figures
- Consistent evidence references
- Clear distinction between confirmed facts and analyst inference
- Professional presentation and readability

SUBMISSION INSTRUCTIONS

1. Submit one report for each phase designated as Report-Required.
2. Submit the final report in PDF format unless otherwise directed.
3. Clearly indicate the team name, phase number, and phase title.
4. Use UTC for timestamps.
5. Major findings must be supported by evidence.
6. Screenshots must be numbered and captioned.
7. Do not include executable malware samples in the report.
8. State 'Not Determined' when a finding cannot be confirmed.
9. Ensure all screenshots, tables, and text are readable.
10. Reports must be submitted before the deadline announced by exercise control.

Evidence Rule: A correct finding without supporting Security Onion, Kibana, Elasticsearch, Zeek, Suricata, or other authorized evidence may receive no more than 50% of the points assigned to that finding. Incorrect or fabricated evidence receives zero points for the affected finding.

4.1 Analyst Findings - Detailed, Step-by-Step Walkthrough (Problems 1-10)

This section answers each of the 10 Phase 1 investigation questions in order. Each problem has its own heading below so you can jump directly to it using Word's Navigation Pane (View > Navigation Pane) or the Table of Contents on page 2. Every answer is backed by at least two screenshots taken directly from the Security Onion investigation platform: one showing the query/search step, and one showing the specific evidence record that produced the answer.

Problem 01 of 10 -- Affected Workstation and DNS Resolver

Question: Which computer was affected, and which DNS server did it use to look up websites?

In plain terms

One computer on the network got hacked. Its number-name is 160.9.3.101. To visit any website, a computer must first ask a helper computer for directions - this is called a DNS server. This computer's helper was 160.9.3.1.

Technical method

Query: `event.dataset:"zeek.dns" AND destination.port:53 | groupby source.ip --` run across the whole evidence set to list every computer making real DNS lookups. Ten candidate hosts appeared; most belonged to unrelated 2024-dated sample data. The host with the earliest 2025-10-01 activity, 160.9.3.101, sent 51 of its 53 real DNS lookups to 160.9.3.1, confirming the workstation/resolver pair.

Answer

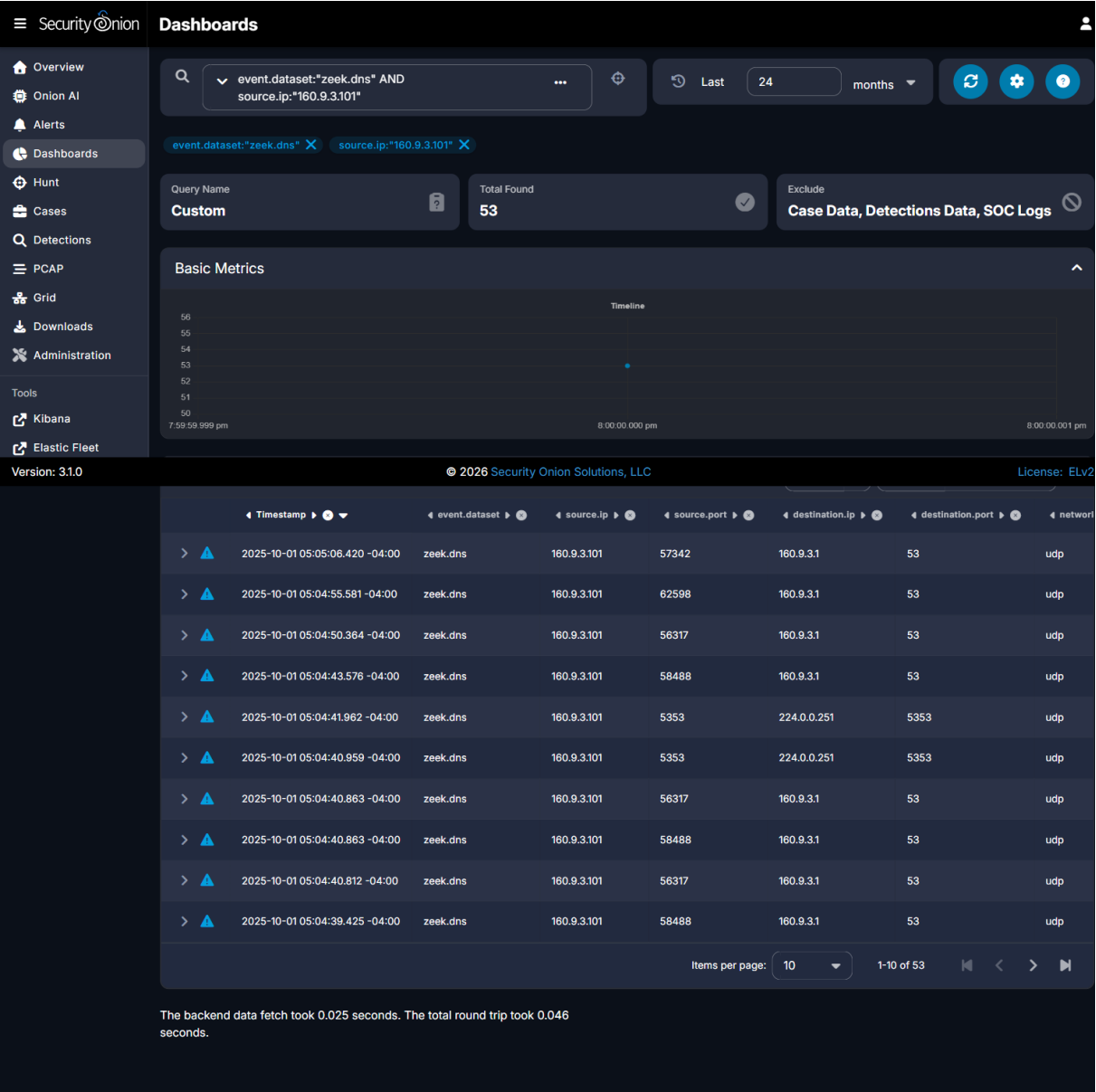
Workstation: 160.9.3.101 | DNS Resolver: 160.9.3.1

Submitted flag: `CTK{160.9.3.101|160.9.3.1}`

Status: CONFIRMED CORRECT -- accepted by the challenge platform.

Step-by-step evidence

Step 1 - List every computer's DNS activity and see which server they used



Step 2 - Confirm the exact resolver pairing on the very first record

Security Onion

Overview

Onion AI

Alerts

Dashboards

Hunt

Cases

Detections

PCAP

Grid

Downloads

Administration

Tools

Kibana

Elastic Fleet

Hunt

source.ip:"160.9.3.101" AND event.dataset:"zeek.dns"

Last24 months

source.ip:"160.9.3.101" event.dataset:"zeek.dns"

Query NameCustom

Total Found53

ExcludeCase Data, Detections Data, SOC Logs, Onion AI Data

Basic Metrics

Timeline

7:59:59.999 pm8:00:00.000 pm8:00:00.001 pm

Fetch Limit

Version: 3.1.02026 Security Onion Solutions, LLCLicense: ELV2

Timestamp

event.dataset

source.ip

source.port

destination.ip

destination.port

network

2025-10-01 05:00:00.000 -04:00

zeek.dns

160.9.3.101

52322

160.9.3.1

53

udp

@timestamp

2025-10-01T09:00:00.000Z

@version

1

client.ip

160.9.3.101

client.port

52322

container.id

logs

data_stream.dataset

import

data_stream.namespace

so

data_stream.type

logs

destination.as.ip

160.9.3.1

destination.as.network

160.9.0.0/16

destination.as.number

786

destination.as.organization.name

Jisc Services Limited

destination.geo.city_name

Leeds

destination.geo.continent_name

Europe

destination.geo.country_iso_code

GB

destination.geo.country_name

United Kingdom

destination.geo.ip

160.9.3.1

destination.geo.location.lat

53.8226

destination.geo.location.lon

-1.568

destination.geo.region_iso_code

GB-LDS

destination.geo.region_name

Leeds

destination.geo.timezone

Europe/London

destination.ip

160.9.3.1

destination.port

53

dns.answers.name

["sepco.com","148.72.11.102"]

dns.authoritative

false

dns.highest_registered_domain

sepco.com

dns.id

2501

Problem 02 of 10 -- First Web Domain

Question: What was the first website the victim computer visited, and what address did it lead to?

In plain terms

The very first thing the computer did was visit a website called `www.sepco.com`. That website looked real but was actually a trick, made to look like a 'verification' page. The trick website's address was `148.72.11.102`.

Technical method

Query: `source.ip:"160.9.3.101"` sorted ascending by Timestamp. The very first record (timestamped exactly at the start of the capture window) is a DNS query for `www.sepco.com`, which resolved to a single, unambiguous address.

Answer

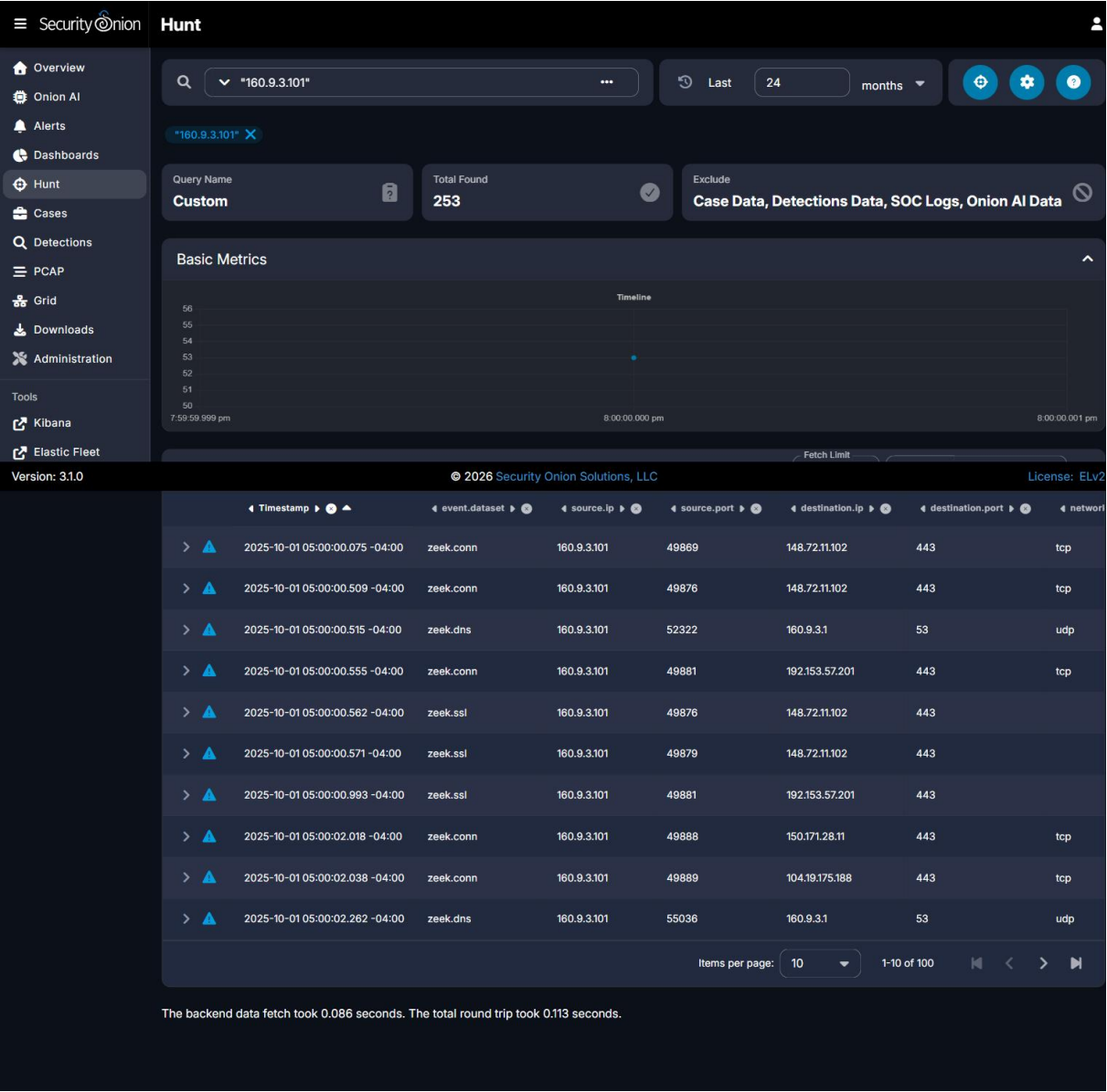
Domain: `www.sepco.com` | **IP Address:** `148.72.11.102`

Submitted flag: `CTK{www.sepco.com|148.72.11.102}`

Status: **CONFIRMED CORRECT -- accepted by the challenge platform.**

Step-by-step evidence

Step 1 - Pull every event for the victim computer, sorted oldest first



Step 2 - Expand the very first record to read the full domain and IP

Security Onion

Hunt

Overview

Onion AI

Alerts

Dashboards

Hunt

Cases

Detections

PCAP

Grid

Downloads

Administration

Tools

Kibana

Elastic Fleet

160.9.3.101

Last24 months

Query NameCustom

Total Found253

ExcludeCase Data, Detections Data, SOC Logs, Onion AI Data

Basic Metrics

Timeline

270

265

260

255

250

245

240

7:58:58.999 pm

8:00:00.000 pm

8:00:00.001 pm

2026 Security Onion Solutions, LLC

License: ELV2

Timestamp

event.dataset

source.ip

source.port

destination.ip

destination.port

network.transport

2025-10-01 05:00:00.000 -04:00

zeek.dns

160.9.3.101

52322

160.9.3.1

53

udp

@timestamp

2025-10-01T09:00:00.000Z

@version

1

client.ip

160.9.3.101

client.port

52322

container.id

logs

data_stream.dataset

import

data_stream.namespace

so

data_stream.type

logs

destination.as.ip

160.9.3.1

destination.as.network

160.9.0.0/16

destination.as.number

786

destination.as.organization.name

Jisc Services Limited

destination.geo.city_name

Leeds

destination.geo.continent_name

Europe

destination.geo.country_iso_code

GB

destination.geo.country_name

United Kingdom

destination.geo.ip

160.9.3.1

destination.geo.location.lat

53.8228

destination.geo.location.lon

-1.568

destination.geo.region_iso_code

GB-LDS

destination.geo.region_name

Leeds

destination.geo.timezone

Europe/London

destination.ip

160.9.3.1

destination.port

53

dns.answers.name

["sepc.com", "148.72.11.102"]

dns.authoritative

false

dns.highest_registered_domain

sepc.com

dns.id

252

Problem 03 of 10 -- Next TLS Server Name

Question: Right after visiting that first website, what site did the computer secretly connect to next?

In plain terms

Right after the trick website, the computer was sent to a second, different website - without anyone clicking anything. That second website was called loughlas.com, at address 192.153.57.201.

Technical method

Query: source.ip:"160.9.3.101" AND event.dataset:"zeek.ssl". After 6 parallel sessions to www.sepco.com, the very next distinct TLS session (server_name field) is to a different domain.

Answer

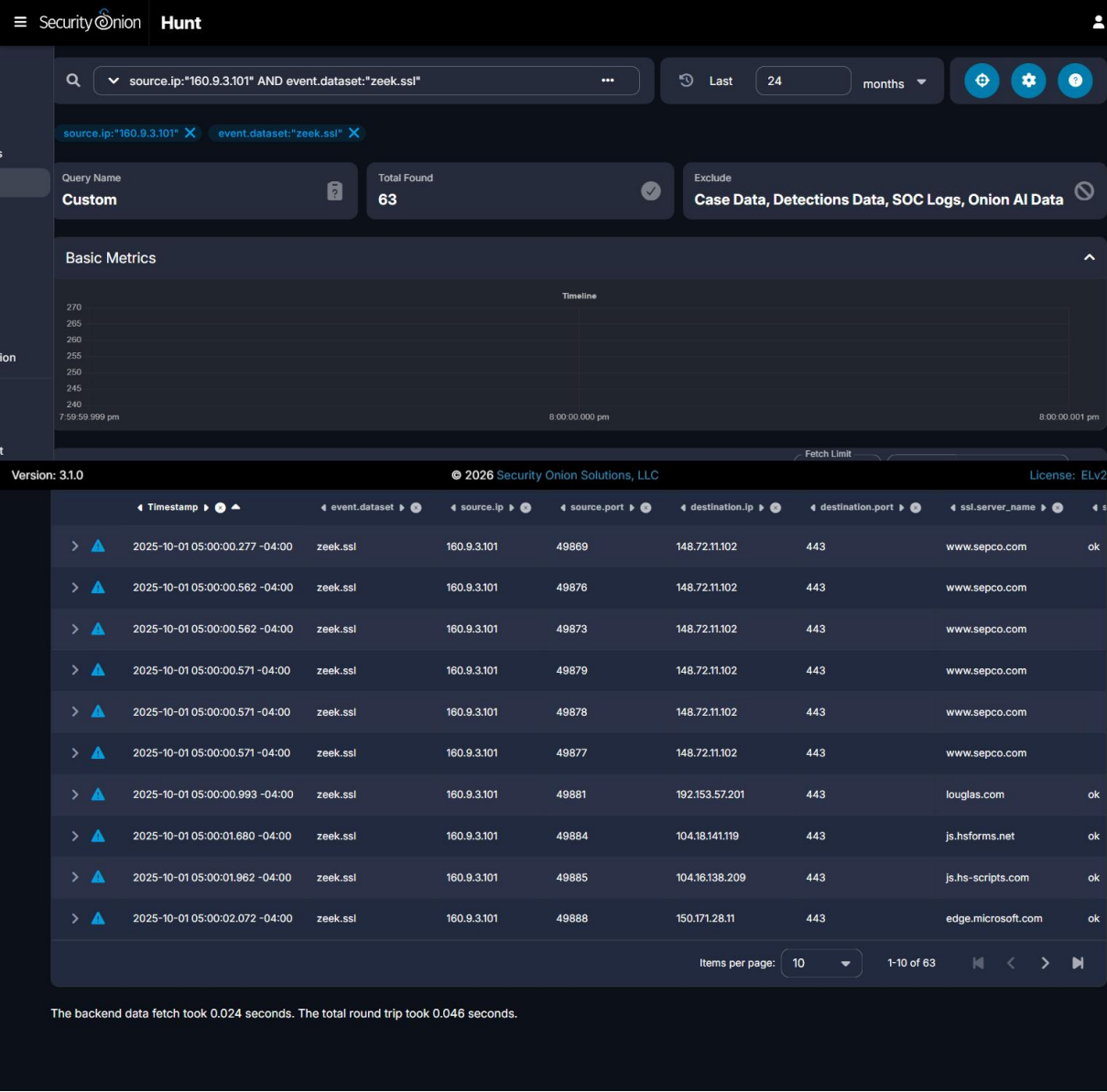
Domain: loughlas.com | **IP Address:** 192.153.57.201

Submitted flag: CTK{loughlas.com|192.153.57.201}

Status: CONFIRMED CORRECT -- accepted by the challenge platform.

Step-by-step evidence

Step 1 - List all secure (TLS) connections in time order to see the full sequence



Step 2 - Expand the specific record for the second site to confirm its name and address

Security Onion

Overview

Onion AI

Alerts

Dashboards

Hunt

Cases

Detections

PCAP

Grid

Downloads

Administration

Tools

Kibana

Elastic Fleet

Hunt

log.id.uid:"CPyXoy4rWDbQ11fY4"

Last24months

log.id.uid:"CPyXoy4rWDbQ11fY4"

Query NameCustomTotal Found2ExcludeCase Data, Detections Data, SOC Logs, Onion AI Data

Basic Metrics

Timeline

565554535251507:59:59.999 pm8:00:00.000 pm8:00:00.001 pm

Fetch Limit

Version: 3.1.0

© 2026 Security Onion Solutions, LLC

License: ELv2

Timestamp

event.dataset

source.ip

source.port

destination.ip

destination.port

ssl.serv

2025-10-01 05:00:00.555 -04:00

zeek.conn

160.9.3.101

49881

192.153.57.201

443

@timestamp

2025-10-01T09:00:00.555Z

@version

1

client.bytes

860

client.ip

160.9.3.101

client.ip.bytes

1232

client.oui

Hewlett Packard

client.packets

9

client.port

49881

connection.bytes.missed

0

connection.history

ShADadfR

connection.local.originator

false

connection.local.responder

false

connection.state

RSTO

connection.state.description

Connection established, originator aborted (sent a RST)

container.id

logs

data_stream.dataset

import

data_stream.namespace

so

data_stream.type

logs

destination.as.ip

192.153.57.201

destination.as.network

192.153.57.0/24

destination.as.number

399629

destination.as.organization.name

BL Networks

destination.geo.city.name

Amsterdam

destination.geo.continent.name

Europe

destination.geo.country_iso_code

NL

destination.geo.country.name

The Netherlands

destination.geo.ip

192.153.57.201

destination.geo.location.lat

52.3716

Problem 04 of 10 -- PowerShell Delivery Server

Question: Which server actually delivered the malicious PowerShell files to the victim, and on what port?

In plain terms

A bad computer far away sent two harmful files to the victim's computer. That bad computer's address was 85.209.129.105. It used a special 'door' (called a port) numbered 2020 to send the files - not the normal doors websites use.

Technical method

Query: source.ip:"160.9.3.101" AND event.dataset:"zeek.file". Two PowerShell scripts (scriptv2.ps1, test.ps1) and a large archive (test.zip) were all delivered from the same server over TCP port 2020 - not the normal web port 80/443.

Answer

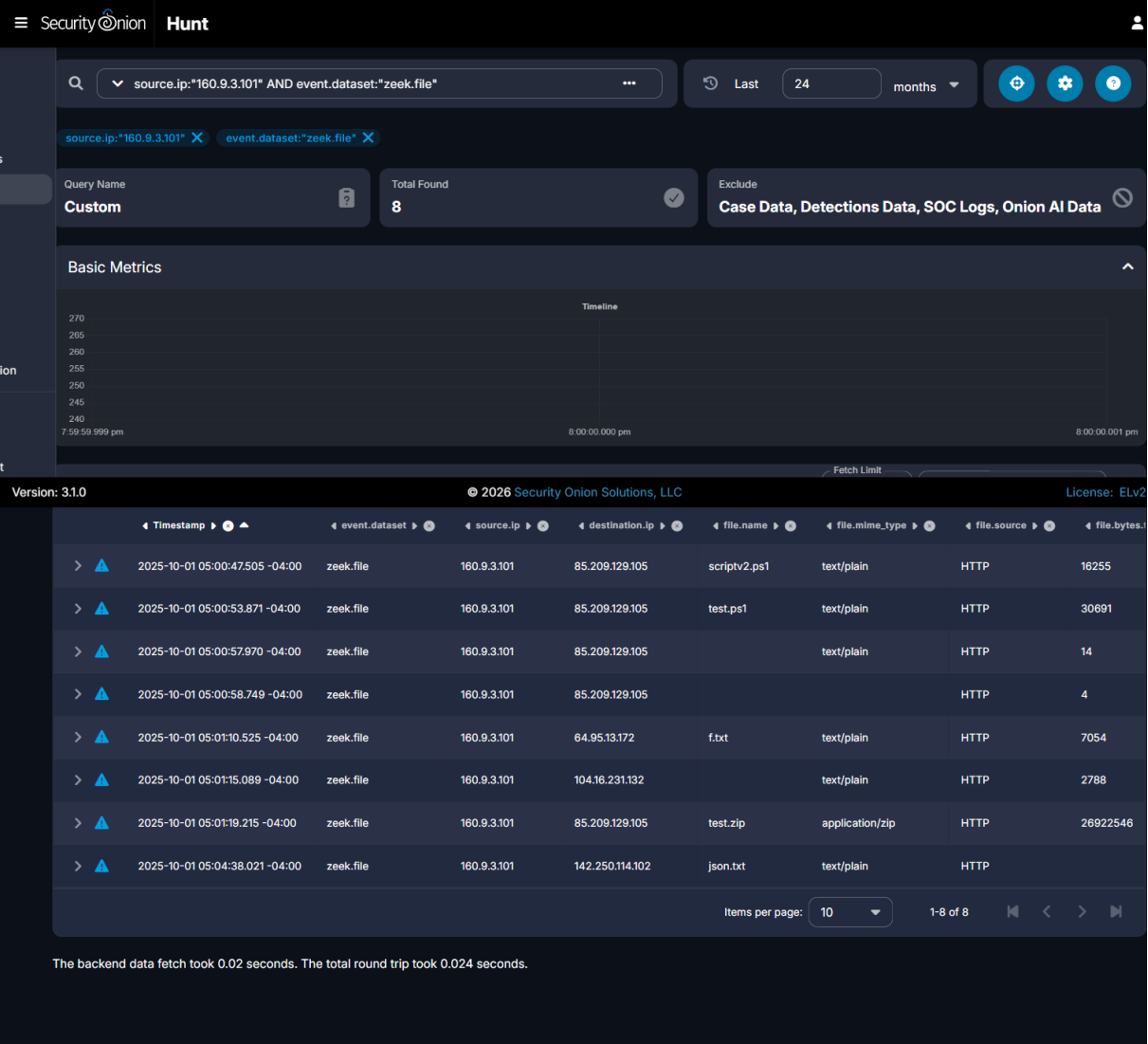
Server: 85.209.129.105 | Port: 2020

Submitted flag: CTK{85.209.129.105|2020}

Status: CONFIRMED CORRECT -- accepted by the challenge platform.

Step-by-step evidence

Step 1 - List every file the victim computer downloaded



Step 2 - Expand one script's record to confirm the exact server and port

Security Onion

Overview

Onion AI

Alerts

Dashboards

Hunt

Cases

Detections

PCAP

Grid

Downloads

Administration

Tools

Kibana

Elastic Fleet

Hunt

log.id.fuid:"FEyXoY2QnMecF2y39"

Last24 months

log.id.fuid:"FEyXoY2QnMecF2y39"

Query NameCustom

Total Found1

ExcludeCase Data, Detections Data, SOC Logs, Onion AI Data

Basic Metrics

Timeline

565554535251507:59:59.999 pm8:00:00.000 pm8:00:00.001 pm

Fetch Limit

Version: 3.1.02026 Security Onion Solutions, LLCLicense: ELv2

Timestampevent.datasetsource.ipdestination.ipfile.namefile_mime_typefile_source

2025-10-01 05:00:47:505 -04:00zeek.file160.9.3.10185.209.129.105scriptv2.ps1text/plainHTTP

@timestamp2025-10-01T09:00:47:50SZ

@version1

client.ip160.9.3.101

client.port63641

container.idlogs

data_stream.datasetimport

data_stream.namespaceso

data_stream.typelogs

destination.as.ip85.209.129.105

destination.as.network85.209.129.0/24

destination.as.number213702

destination.as.organization_nameQWINS LTD

destination.geo.city_nameHelsinki

destination.geo.continent_nameEurope

destination.geo.country_iso_codeFI

destination.geo.country_nameFinland

destination.geo.ip85.209.129.105

destination.geo.location.lat60.1719

destination.geo.location.lon24.9347

destination.geo.region_iso_codeFI-18

destination.geo.region_nameUusimaa

destination.geo.timezoneEurope/Helsinki

destination.ip85.209.129.105

destination.port2020

ecs.version8.0.0

elastic_agent.id5045ad9f-47fc-4a24-be96-5a6e13dbd51d

elastic_agent.snapshotfalse

elastic_agent.version9.3.3+build202604082258

Problem 05 of 10 -- First Script Delivery

Question: What exact web address delivered the very first malicious script, and what was that file called?

In plain terms

The first harmful file was named scriptv2.ps1. It is a small program written for Windows PowerShell (a tool built into Windows for running commands). It was fetched from a specific spot on the bad computer called /19.

Technical method

Query: source.ip:"160.9.3.101" AND event.dataset:"zeek.http". The first request to the delivery server (09:00:47 UTC) is a GET to /19, using the curl tool, returning a file recorded as scriptv2.ps1.

Answer

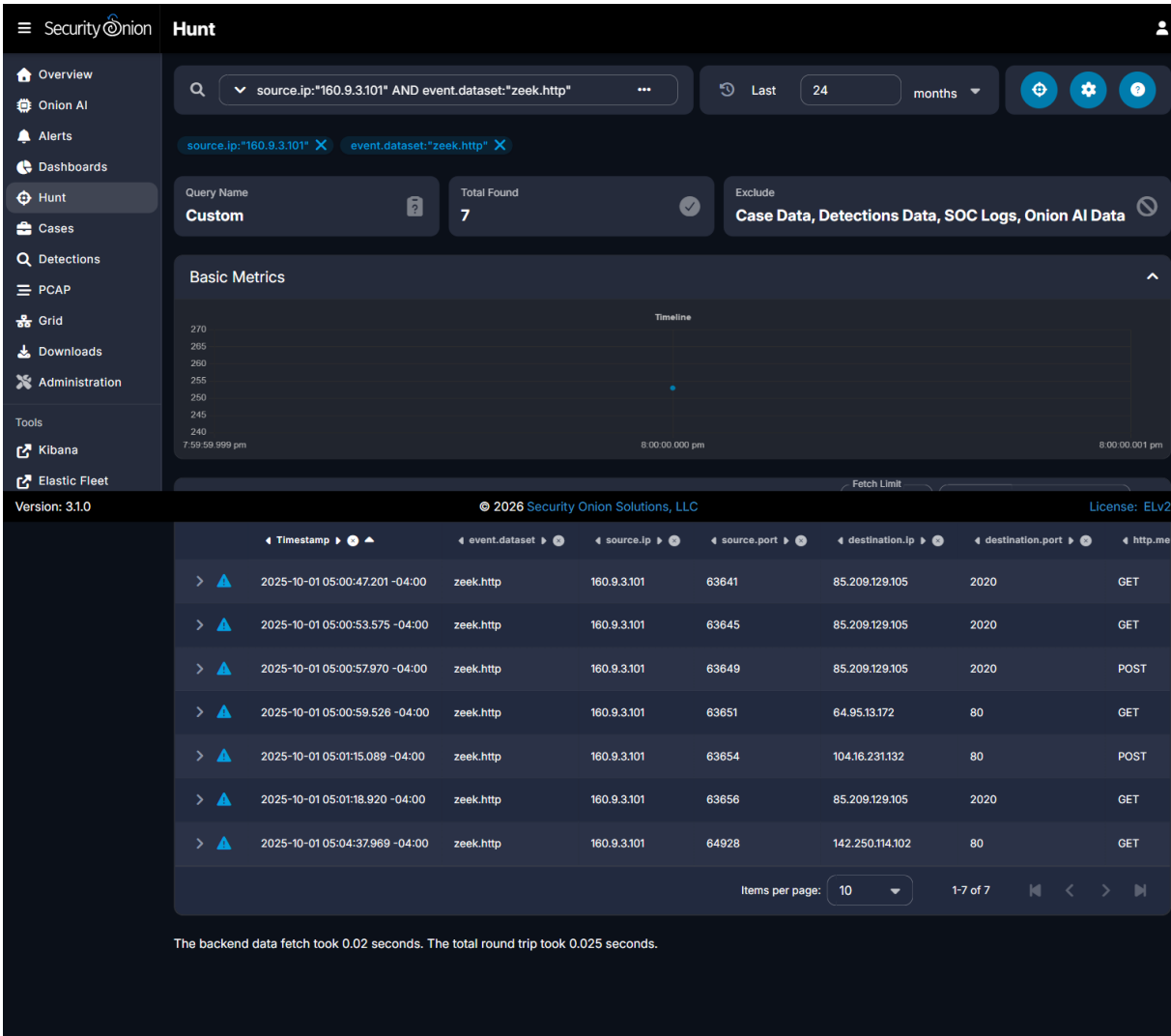
URI: /19 | Filename: scriptv2.ps1

Submitted flag: CTK{/19|scriptv2.ps1}

Status: **CONFIRMED CORRECT** -- accepted by the challenge platform.

Step-by-step evidence

Step 1 - List all web requests the victim computer made to the delivery server



Step 2 - Expand the very first request to read its exact address and filename

Security Onion

Overview

Onion AI

Alerts

Dashboards

Hunt

Cases

Detections

PCAP

Grid

Downloads

Administration

Tools

Kibana

Elastic Fleet

Hunt

log.id.uid:"CqGE2b39Yb7ePbbQ25" AND event.dataset:"zeek.http"

Last24 months

log.id.uid:"CqGE2b39Yb7ePbbQ25"

event.dataset:"zeek.http"

Query NameCustom

Total Found1

ExcludeCase Data, Detections Data, SOC Logs, Onion AI Data

Basic Metrics

Timeline

270

265

260

255

250

245

240

7:59:59.999 pm

8:00:00.000 pm

8:00:00.001 pm

© 2026 Security Onion Solutions, LLC

License: ELv2

Timestamp

event.dataset

source.ip

source.port

destination.ip

destination.port

http.method

2025-10-01 05:00:47.201 -04:00

zeek.http

160.9.3.101

63641

85.209.129.105

2020

GET

@timestamp

2025-10-01T09:00:47.201Z

@version

1

client.ip

160.9.3.101

client.port

63641

container.id

logs

data_stream.dataset

import

data_stream.namespace

so

data_stream.type

logs

destination.as.ip

85.209.129.105

destination.as.network

85.209.129.0/24

destination.as.number

213702

destination.as.organization.name

QWINS LTD

destination.geo.city_name

Helsinki

destination.geo.continent_name

Europe

destination.geo.country_iso_code

FI

destination.geo.country_name

Finland

destination.geo.ip

85.209.129.105

destination.geo.location.lat

60.1719

destination.geo.location.lon

24.9347

destination.geo.region_iso_code

FI-18

destination.geo.region_name

Uusimaa

destination.geo.timezone

Europe/Helsinki

destination.ip

85.209.129.105

destination.port

2020

ecs.version

8.0.0

elastic_agent.id

5045ad9f-47fc-4a24-be96-5a6e13dbd51d

elastic_agent.snapshot

false

elastic_agent.version

9.3.3+build202604082258

Problem 06 of 10 -- Second Script Delivery

Question: What exact web address delivered the second malicious script, and what was it called?

In plain terms

A second harmful file came next, named test.ps1. It came from a spot called /test112. This time, it was Windows PowerShell itself - not a simple download tool - that fetched it, which tells us the first file had already started running on its own.

Technical method

Query: source.ip:"160.9.3.101" AND event.dataset:"zeek.http". The second request (09:00:53 UTC) is a GET to /test112, this time with a genuine WindowsPowerShell/5.1 user-agent, returning test.ps1.

Answer

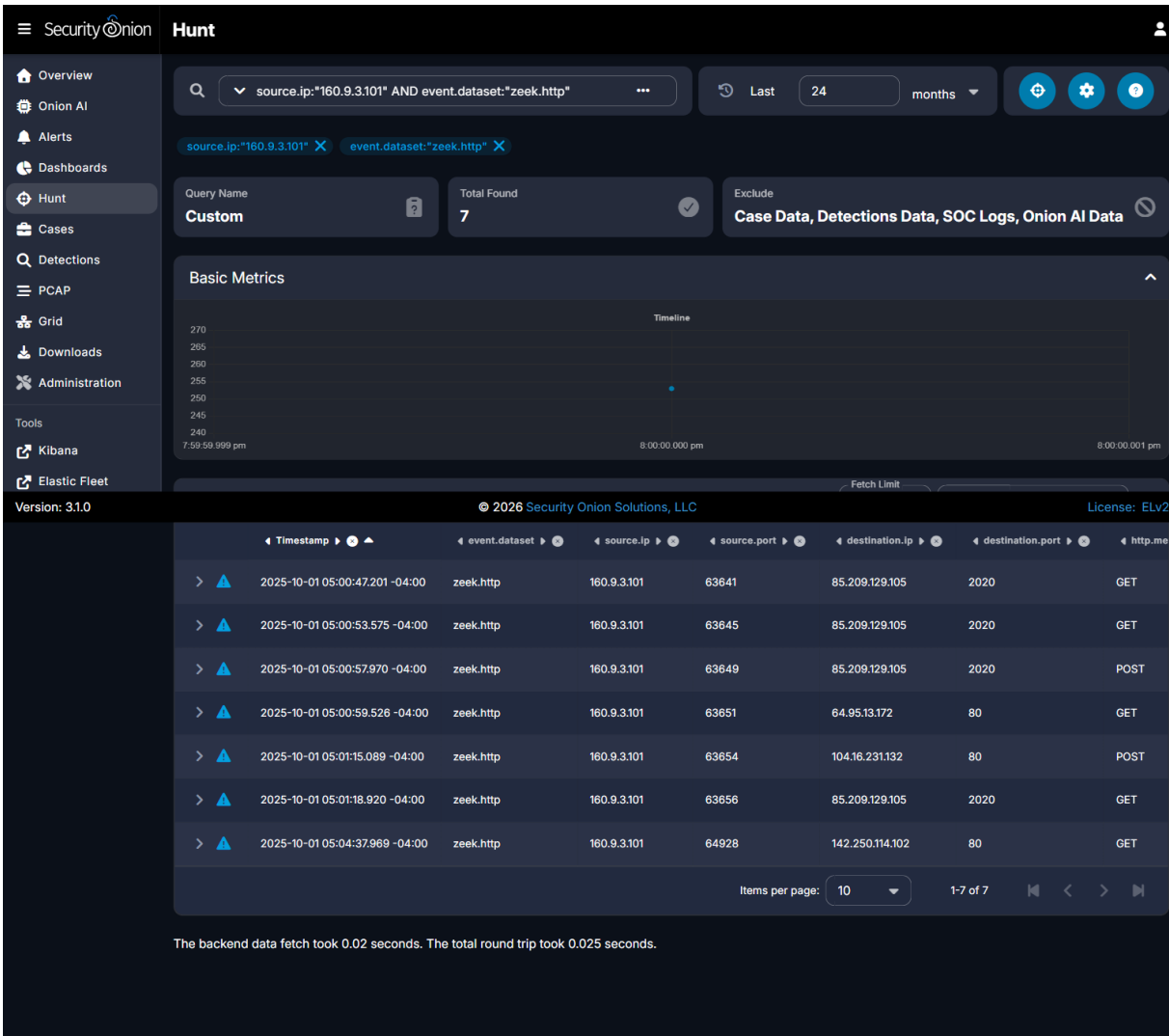
URI: /test112 | **Filename:** test.ps1

Submitted flag: CTK{/test112|test.ps1}

Status: CONFIRMED CORRECT -- accepted by the challenge platform.

Step-by-step evidence

Step 1 - List all web requests the victim computer made to the delivery server



Step 2 - Expand the second request to read its exact address and filename

Security Onion

Hunt

Overview

Onion AI

Alerts

Dashboards

Hunt

Cases

Detections

PCAP

Grid

Downloads

Administration

ELK Stack

Kibana

Elastic Fleet

log.id.uid:"Cktb803yzkrrCkYDyc" AND event.dataset:"zeek.http"

Last24 months

Query Name

atom

Total Found

1

Exclude

Case Data, Detections Data, SOC Logs, Onion AI Data

Basic Metrics

Timeline

Version: 3.1.0

© 2026 Security Onion Solutions, LLC

License: ELv2

Timestamp

event.dataset

source.ip

source.port

destination.ip

destination.port

http.method

2025-10-01 05:00:53.575 -04:00

zeek.http

160.9.3.101

63645

85.209.129.105

2020

GET

@timestamp

2025-10-01T09:00:53.575Z

@version

1

client.ip

160.9.3.101

client.port

63645

container.id

logs

data_stream.dataset

import

data_stream.namespace

so

data_stream.type

logs

destination.as.ip

85.209.129.105

destination.as.network

85.209.129.0/24

destination.as.number

213702

destination.as.organization.name

QWINS LTD

destination.geo.city.name

Helsinki

destination.geo.continent.name

Europe

destination.geo.country_iso_code

FI

destination.geo.country.name

Finland

destination.geo.ip

85.209.129.105

destination.geo.location.lat

60.1719

destination.geo.location.lon

24.9347

destination.geo.region_iso_code

FI-18

destination.geo.region.name

Uusimaa

destination.geo.timezone

Europe/Helsinki

destination.ip

85.209.129.105

destination.port

2020

ecs.version

8.0.0

elastic_agent.id

5045ad9f-47fc-4a24-be96-5a6e13dbd51d

elastic_agent.snapshot

false

elastic_agent.version

9.3.3+build202604082258

Problem 07 of 10 -- Notification Request

Question: After the scripts ran, how did the victim computer 'report back' success, and what happened?

In plain terms

After the files ran, the victim's computer sent a tiny message back to the bad computer, almost like saying 'it worked!' The message went to a spot called /notify, and the bad computer answered back 'OK' (in computer terms, this is called a 200 status).

Technical method

Query: source.ip:"160.9.3.101" AND event.dataset:"zeek.http". At 09:00:57 UTC, a POST request to /notify sent only 14 bytes and received a 4-byte reply with status 200 OK - a classic small check-in/beacon pattern.

Answer

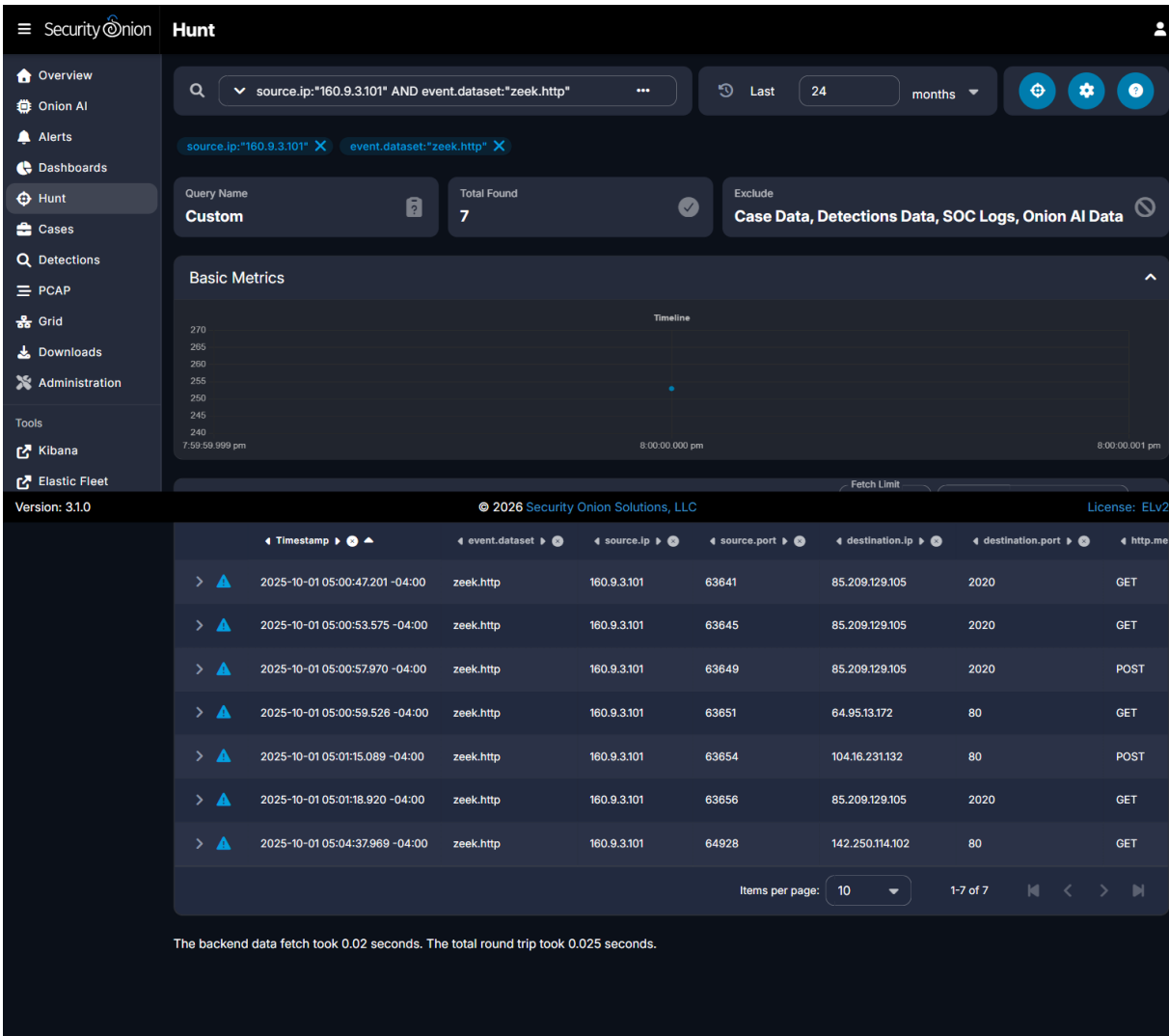
Method: POST | URI: /notify | Response Status: 200

Submitted flag: CTK{POST|/notify|200}

Status: CONFIRMED CORRECT -- accepted by the challenge platform.

Step-by-step evidence

Step 1 - List all web requests the victim computer made to the delivery server



Step 2 - Expand the check-in request to confirm method, address, and response code

Security Onion

Overview

Onion AI

Alerts

Dashboards

Hunt

Cases

Detections

PCAP

Grid

Downloads

Administration

Tools

Kibana

Elastic Fleet

Hunt

log.id.uid:"C8kmUG21ryBXI6qCA8" AND event.dataset:"zeek.http"

Last24 months

log.id.uid:"C8kmUG21ryBXI6qCA8"

event.dataset:"zeek.http"

Query NameCustom

Total Found1

ExcludeCase Data, Detections Data, SOC Logs, Onion AI Data

Basic Metrics

Timeline

270

265

260

255

250

245

240

7:59:59.999 pm

8:00:00.000 pm

8:00:00.001 pm

Version: 3.1.0

© 2026 Security Onion Solutions, LLC

License: ELv2

Timestamp

event.dataset

source.ip

source.port

destination.ip

destination.port

http.method

2025-10-01 05:00:57.970 -04:00

zeek.http

160.9.3.101

63649

85.209.129.105

2020

POST

@timestamp

2025-10-01T09:00:57.970Z

@version

1

client.ip

160.9.3.101

client.port

63649

container.id

logs

data_stream.dataset

import

data_stream.namespace

so

data_stream.type

logs

destination.as.ip

85.209.129.105

destination.as.network

85.209.129.0/24

destination.as.number

213702

destination.as.organization.name

QWINS LTD

destination.geo.city_name

Helsinki

destination.geo.continent_name

Europe

destination.geo.country_iso_code

FI

destination.geo.country_name

Finland

destination.geo.ip

85.209.129.105

destination.geo.location.lat

60.1719

destination.geo.location.lon

24.9347

destination.geo.region_iso_code

FI-18

destination.geo.region_name

Uusimaa

destination.geo.timezone

Europe/Helsinki

destination.ip

85.209.129.105

destination.port

2020

ecs.version

8.0.0

elastic_agent.id

5045ad9f-47fc-4a24-be96-5a6e13dbd51d

elastic_agent.snapshot

false

elastic_agent.version

9.3.3+build202604082258

Problem 08 of 10 -- Cloudflare Tunnel Transaction

Question: What temporary Cloudflare 'tunnel' address did the computer briefly use, and what happened?

In plain terms

The attacker also used a free, temporary 'tunnel' from Cloudflare (a real, trusted company) to hide where they truly were. It was used only once. The far end answered 'not found' (called a 404 status).

Technical method

Query: source.ip:"160.9.3.101" AND event.dataset:"zeek.http". At 09:01:15 UTC, a POST request went to maintaining-shelter-bailey-ordinance.trycloudflare.com at URI /BSVjy5VpVrgO, receiving a 404 Not Found response.

Answer

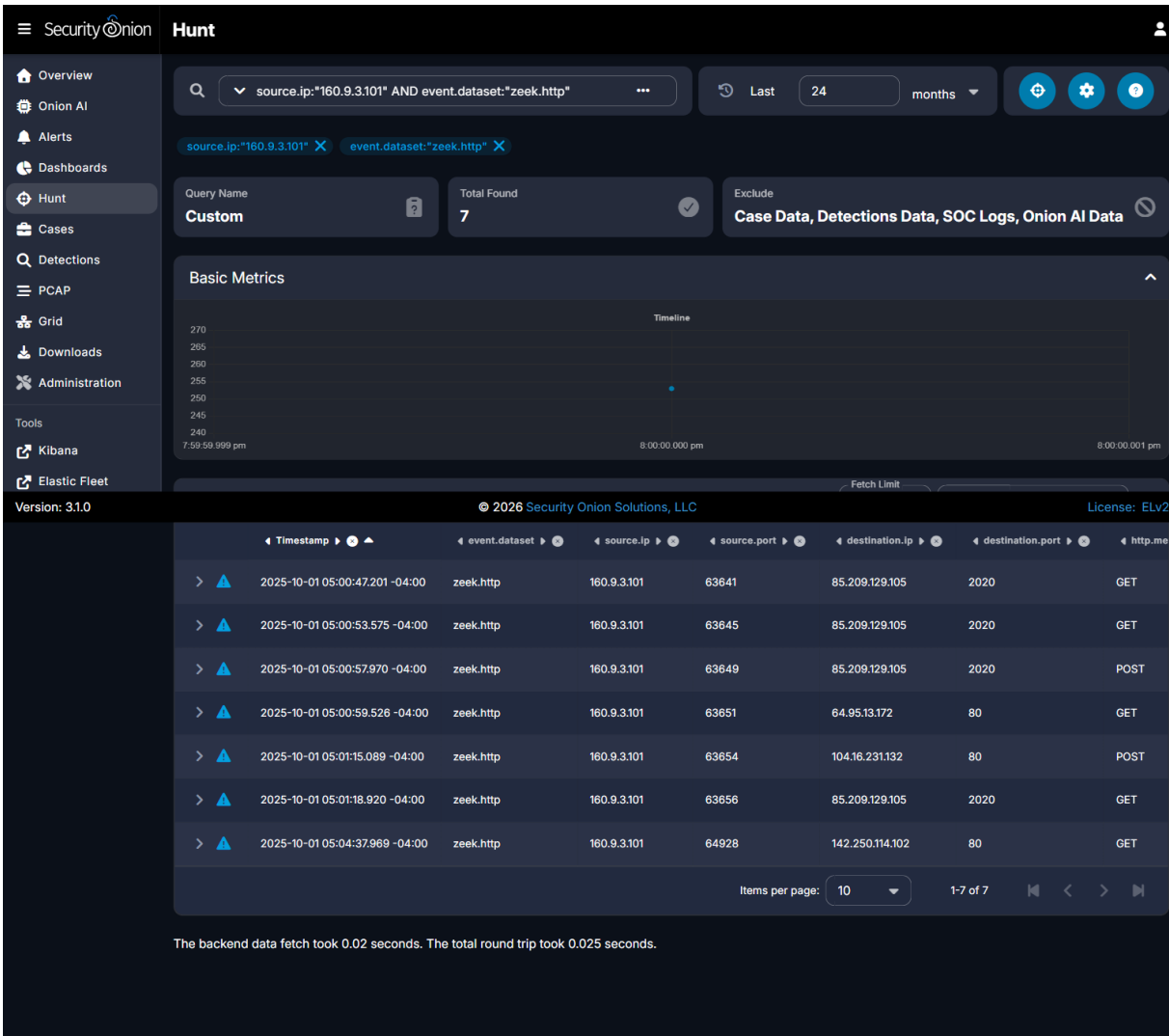
Hostname: maintaining-shelter-bailey-ordinance.trycloudflare.com | **URI:** /BSVjy5VpVrgO | **Status:** 404

Submitted flag: CTK{maintaining-shelter-bailey-ordinance.trycloudflare.com|/BSVjy5VpVrgO|404}

Status: CONFIRMED CORRECT -- accepted by the challenge platform.

Step-by-step evidence

Step 1 - List all web requests the victim computer made around this time



Step 2 - Expand the tunnel request to confirm hostname, address, and response code

Security Onion

Hunt

Overview

Onion AI

Alerts

Dashboards

Hunt

Cases

Detections

PCAP

Grid

Downloads

Administration

Tools

Kibana

Elastic Fleet

log.id.uid:"Cp61j16BYOZNBVlca" AND event.dataset:"zeek.http"

Last24months

⚙️⚙️ⓘ

1

Total Found

Exclude

Case Data, Detections Data, SOC Logs, Onion AI Data

Metrics

Timeline

8:00:00:000 pm8:00:00:001 pm

Fetch Limit

Version: 3.1.0

© 2026 Security Onion Solutions, LLC

License: ELv2

Timestampevent.datasetsource.ipsource.portdestination.ipdestination.porthttp.method

2025-10-01 05:01:15.089 -04:00zeek.http160.9.3.10163654104.16.231.13280POST

@timestamp2025-10-01T09:01:15.089Z

@version1

client.ip160.9.3.101

client.port63654

container.idlogs

data_stream.datasetimport

data_stream.namespaceso

data_stream.typelogs

destination.as.ip104.16.231.132

destination.as.network104.16.0.0/14

destination.as.number13335

destination.as.organization.nameCloudflare, Inc.

destination.geo.ip104.16.231.132

destination.ip104.16.231.132

destination.port80

ecs.version8.0.0

elastic_agent.id5045ad9f-47fc-4a24-be96-5a6e13dbd51d

elastic_agent.snapshotfalse

elastic_agent.version9.3.3+build202604082258

event.agent_id_statusmissing

event.categorynetwork

event.datasetzeek.http

event.importedtrue

event.ingested2026-07-29T13:35:25Z

event.modulezeek

file.orig_mime_types["text/plain"]

hash.sha1pot1nn050000_9c5e2839d274_000000000000_000000000000

http.info_code100

Problem 09 of 10 -- Large Archive Transfer

Question: What web address delivered the large file, what was it called, and exactly how big was it?

In plain terms

The biggest file sent was a large zipped folder - about 26 megabytes, roughly the size of a few hundred photos - named test.zip. It came from a spot called /test11.

Technical method

Query: source.ip:"160.9.3.101" AND event.dataset:"zeek.http". At 09:01:18 UTC, a GET request to /test11 returned a 200 OK response with a body of exactly 26,922,546 bytes, matching the file record for test.zip.

Answer

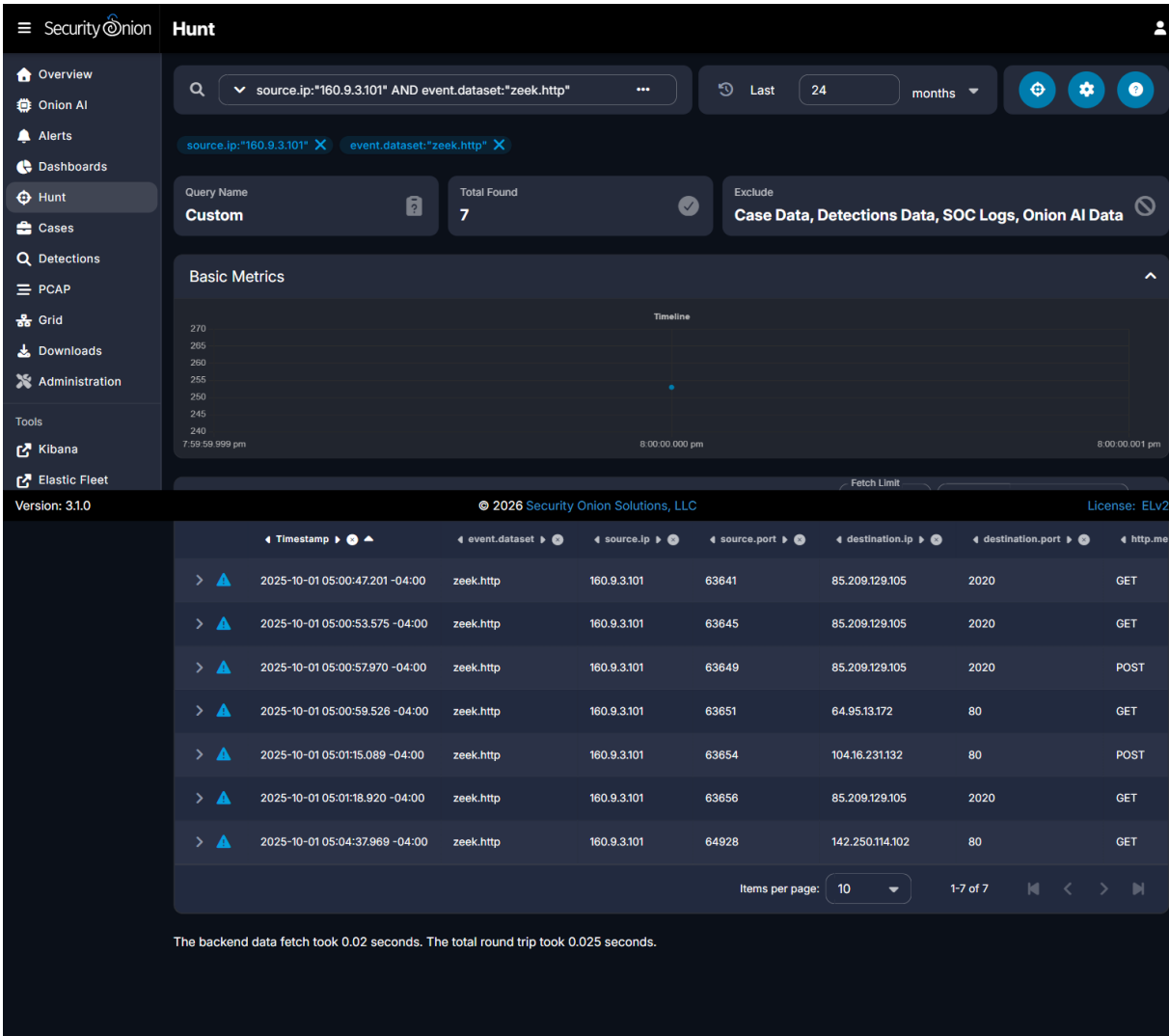
URI: /test11 | **Filename:** test.zip | **Size:** 26,922,546 bytes

Submitted flag: CTK{/test11|test.zip|26922546}

Status: CONFIRMED CORRECT -- accepted by the challenge platform.

Step-by-step evidence

Step 1 - List all web requests the victim computer made to the delivery server



Step 2 - Expand the archive download request to confirm address, filename, and exact size

Security Onion

Overview

Onion AI

Alerts

Dashboards

Hunt

Cases

Detections

PCAP

Grid

Downloads

Administration

Tools

Kibana

Elastic Fleet

Hunt

log.id.uid:"C2qZ713cWuXatbYjDb" AND event.dataset:"zeek.http"

Last24 months

log.id.uid:"C2qZ713cWuXatbYjDb"

event.dataset:"zeek.http"

Query Namecustom

Total Found1

ExcludeCase Data, Detections Data, SOC Logs, Onion AI Data

Basic Metrics

Timeline

Version: 3.1.0

© 2026 Security Onion Solutions, LLC

License: ELv2

Timestamp

event.dataset

source.ip

source.port

destination.ip

destination.port

http.method

2025-10-01 05:01:18.920 -04:00

zeek.http

160.9.3.101

63656

85.209.129.105

2020

GET

@timestamp

2025-10-01T09:01:18.920Z

@version

1

client.ip

160.9.3.101

client.port

63656

container.id

logs

data_stream.dataset

import

data_stream.namespace

so

data_stream.type

logs

destination.as.ip

85.209.129.105

destination.as.network

85.209.129.0/24

destination.as.number

213702

destination.as.organization.name

QWINS LTD

destination.geo.city_name

Helsinki

destination.geo.continent_name

Europe

destination.geo.country_iso_code

FI

destination.geo.country_name

Finland

destination.geo.ip

85.209.129.105

destination.geo.location.lat

60.1719

destination.geo.location.lon

24.9347

destination.geo.region_iso_code

FI-18

destination.geo.region_name

Uusimaa

destination.geo.timezone

Europe/Helsinki

destination.ip

85.209.129.105

destination.port

2020

ecs.version

8.0.0

elastic_agent.id

5045ad9f-47fc-4a24-be96-5a6e13dbd51d

elastic_agent.snapshot

false

elastic_agent.version

9.3.3+build202604082258

Problem 10 of 10 -- Later TLS C2 Domain

Question: After everything else, which website kept getting contacted over and over - likely the attacker's remote-control channel?

In plain terms

After everything else happened, the victim's computer kept quietly calling out to a website named georgej.ru, again and again - nine times in under a minute. This kind of repeated, automatic calling out is how attackers secretly stay in control of a computer they have hacked.

Technical method

Query: source.ip:"160.9.3.101" AND destination.ip:"91.212.166.160" AND event.dataset:"zeek.ssl". Found 9 TLSv1.3 sessions between 09:04:35 and 09:05:06 UTC, all with server_name georgej.ru.

Answer

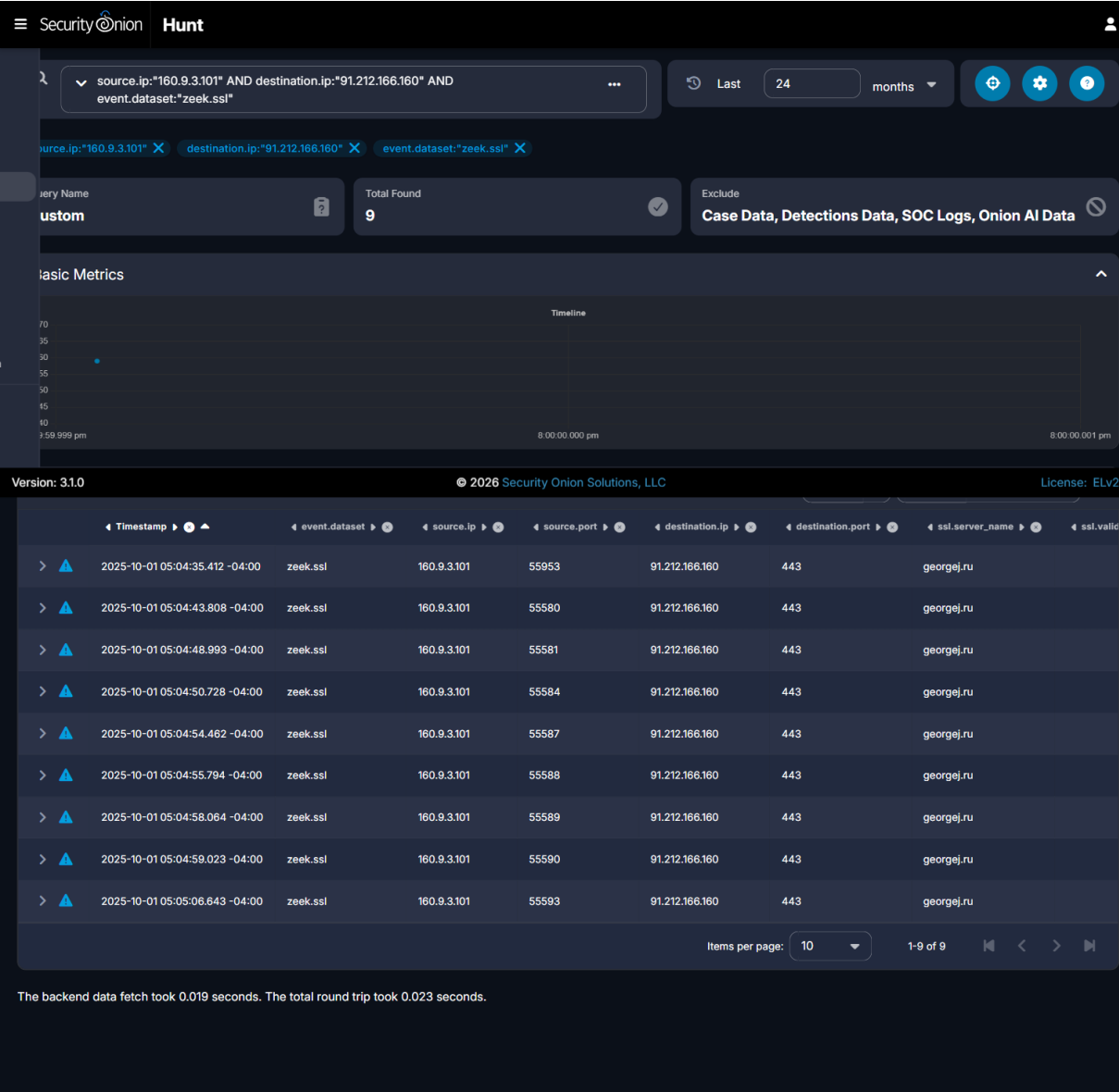
Domain: georgej.ru (resolves to 91.212.166.160)

Submitted flag: CTK{georgej.ru}

Status: CONFIRMED CORRECT -- accepted by the challenge platform.

Step-by-step evidence

Step 1 - List every secure connection to the suspicious IP address



Step 2 - Expand one session to confirm the domain name tied to that address

Security Onion

Overview

Onion AI

Alerts

Dashboards

Hunt

Cases

Detections

PCAP

Grid

Downloads

Administration

Tools

Kibana

Elastic Fleet

Hunt

log.id.uid:"Cayp7x1osJH5m9henj"

Last24months

g.id.uid:"Cayp7x1osJH5m9henj"

Query Name: custom

Total Found: 2

Exclude: Case Data, Detections Data, SOC Logs, Onion AI Data

Basic Metrics

Timeline

Version: 3.1.0

© 2026 Security Onion Solutions, LLC

License: ELv2

Timestamp

event.dataset

source.ip

source.port

destination.ip

destination.port

ssl_server_name

2025-10-01 05:04:35.224 -04:00

zeek.conn

160.9.3.101

55953

91.212.166.160

443

@timestamp

2025-10-01T09:04:35.224Z

@version

1

client.bytes

1819

client.ip

160.9.3.101

client.ip.bytes

2511

client.oui

Hewlett Packard

client.packets

17

client.port

55953

connection.bytes.missed

0

connection.history

ShADadR

connection.local.originator

false

connection.local.responder

false

connection.state

RSTO

connection.state.description

Connection established, originator aborted (sent a RST)

container.id

logs

data_stream.dataset

import

data_stream.namespace

so

data_stream.type

logs

destination.as.ip

91.212.166.160

destination.as.network

91.212.166.0/24

destination.as.number

41798

destination.as.organization.name

JSC Transtelecom

destination.geo.city.name

Astana

destination.geo.continent.name

Asia

destination.geo.country_iso_code

KZ

destination.geo.country.name

Kazakhstan

destination.geo.ip

91.212.166.160

destination.geo.location.lat

51.1876

